Vertrag zur Auftragsverarbeitung

eeziframes · Konfigurator-Pakete EEZI Essential, EEZI Essential Plus und EEZI Signature · Fassung vom 28. Oktober 2026

nach Art. 28 DSGVO zwischen Ihnen als Verantwortlichem („Auftraggeber“) und Patrick Kies, eeziframes, Postweg 35, 33442 Herzebrock-Clarholz, als Auftragsverarbeiter („Auftragnehmer“). Er gilt mit jedem Paketvertrag und endet mit ihm; die Pflichten zur Löschung (§ 11) gelten darüber hinaus.

§ 1 Gegenstand und Dauer

Der Auftragnehmer betreibt für den Auftraggeber den Fenster-Konfigurator des Pakets und verarbeitet dabei personenbezogene Daten im Auftrag des Auftraggebers. Die Verarbeitung dauert so lange wie der Paketvertrag, zuzüglich der Fristen in § 11.

§ 2 Art und Zweck der Verarbeitung

- Entgegennehmen und Speichern der Planungen und Anfragen, die Kunden des Auftraggebers im Konfigurator eingeben, samt Fotos;
- Auswertung der Fotos durch eine KI, nur wenn der Kunde im Konfigurator eingewilligt hat;
- Erzeugen des Aufmaßblatts als PDF und Versand der Anfrage per E-Mail an die bestätigten Adressen des Auftraggebers, mit Verfolgung der Zustellung;
- bei Signature: Bereitstellen im Dashboard unter der Domain des Auftraggebers, persönliche Einladungslinks, Fortschritt, Ablage der Aufmaßblätter, Export;
- Schutz vor Missbrauch (Zählung je IP-Adresse, dauerhaft nur als gekürzter Prüfwert, Frist in § 11) und Löschung nach den Fristen in § 11.

§ 3 Art der Daten und Kreis der Betroffenen

Betroffene: Interessenten und Kunden des Auftraggebers, die den Konfigurator nutzen; Mitarbeiter des Auftraggebers, deren Adressen Anfragen empfangen oder die einen Zugang zum Dashboard haben.

Daten: Kontaktdaten (Name, Telefon, E-Mail, gewünschte Erreichbarkeit, auf Wunsch Adresse des Objekts), Planungsdaten (Fenster, Maße, Wünsche, Notizen), Fotos der Fenster (sie können Räume, Gegenstände oder Personen zeigen), Zeitpunkt und Fassung der Einwilligung zur KI-Auswertung, Inhalte und Zustelldaten der E-Mails, technische Daten (IP-Adresse kurzzeitig, Zeitpunkte); bei Signature außerdem E-Mail-Adresse, Name und Anmeldezeiten der Dashboard-Zugänge. Besondere Kategorien nach Art. 9 DSGVO werden nicht gezielt erhoben; Fotos können solche Angaben unbeabsichtigt zeigen (etwa Hilfsmittel in einem Raum).

§ 4 Weisungen

Der Auftragnehmer verarbeitet die Daten nur auf dokumentierte Weisung des Auftraggebers. Weisungen sind dieser Vertrag, die Einstellungen des Pakets und Ihre Angaben im Kundenkonto sowie Einzelweisungen in Textform. Mit der Bestellung weist der Auftraggeber an, die Daten so zu verarbeiten, wie es die Paketbedingungen, die Leistungsübersicht und diese Anlage beschreiben, einschließlich der KI-Auswertung mit Einwilligung des Kunden, der Fristen und der Zählung ohne Personenbezug (§ 10 Abs. 3 der Paketbedingungen). Hält der Auftragnehmer eine Weisung für rechtswidrig, sagt er es dem Auftraggeber unverzüglich und darf sie aussetzen, bis der Auftraggeber sie bestätigt oder ändert. Weisungen, die über den Umfang des Pakets hinausgehen, behandelt der Auftragnehmer als Wunsch nach einer zusätzlichen Leistung, die er gesondert anbieten oder ablehnen kann; lehnt er sie ab, kann der Auftraggeber den Paketvertrag zum Ende des Abrechnungsmonats kündigen.

§ 5 Vertraulichkeit

Wer beim Auftragnehmer Zugang zu den Daten hat, ist zur Vertraulichkeit verpflichtet. In die Anfragen sieht der Auftragnehmer nur, wenn der Auftraggeber darum bittet oder es zur Behebung einer Störung nötig ist; solche Einblicke dokumentiert er.

§ 6 Technische und organisatorische Maßnahmen

- Übertragung nur verschlüsselt (TLS); Datenbank und Dateien bei Supabase in Frankfurt am Main, verschlüsselt gespeichert, in nicht öffentlichen Ablagen, auf die nur der Server zugreift;
- Trennung der Mandanten: Jede Anfrage gehört genau einem Konfigurator und ist nur über dessen Domain und dessen Dashboard erreichbar;
- Zugang zur Verwaltung des Auftragnehmers mit Passwort und zweitem Faktor, Sitzungen nur im geschützten Cookie, Protokoll aller Eingriffe;
- Anmeldung zum Dashboard nur mit Code per E-Mail an bestätigte Zugänge, eigene Sitzung je Domain;
- Begrenzung von Anfragen je IP-Adresse und je Konfigurator gegen Missbrauch, je Anschluss gespeichert nur als Prüfwert mit Geheimnis;
- tägliche Sicherung der Datenbank durch Supabase, sieben Tage aufbewahrt; Löschung nach festen Fristen, automatisch (§ 11).

§ 7 Unterauftragnehmer

Der Auftraggeber genehmigt die folgenden Unterauftragnehmer. Neue oder geänderte kündigt der Auftragnehmer mindestens vier Wochen vorher in Textform an; der Auftraggeber kann aus wichtigem datenschutzrechtlichem Grund widersprechen und, falls keine Lösung gefunden wird, den Paketvertrag zum Wechsel kündigen. Muss ein Unterauftragnehmer kurzfristig ersetzt werden (Ausfall, Sicherheitsproblem, Einstellung des Dienstes), kündigt der Auftragnehmer den Ersatz so früh wie möglich in Textform an, mindestens 14 Tage vorher; bis dahin setzt er die betroffene Funktion aus, soweit der Konfigurator ohne sie weiterläuft. Der Auftraggeber kann widersprechen und den Paketvertrag zum Wechsel kündigen. Der Auftragnehmer verpflichtet seine Unterauftragnehmer vertraglich auf gleichwertige Pflichten zum Schutz der Daten (Art. 28 Abs. 4 DSGVO).

Unterauftragnehmer	Leistung	Ort, Übermittlung
Cloudflare, Inc., San Francisco, USA	Auslieferung des Konfigurators, Server-Programm, Zwischenspeicher, Domain und DNS	weltweit verteilt; EU-US Data Privacy Framework, ergänzend Standardvertragsklauseln
Supabase Inc., USA	Datenbank, Ablage der Fotos und Aufmaßblätter, Anmeldung der Dashboard-Zugänge	Frankfurt am Main; Standardvertragsklauseln für Zugriffe aus Drittländern (Support)
Plus Five Five, Inc. (Resend), San Francisco, USA	Versand der E-Mails, Zustellprotokolle (30 Tage)	USA; EU-US Data Privacy Framework, ergänzend Standardvertragsklauseln
Anthropic Ireland, Limited, Dublin, Irland	KI-Auswertung der Fotos, nur mit Einwilligung des Kunden; keine Nutzung zum Training, Löschung in der Regel nach 30 Tagen (länger nur, wenn Anthropic einen Verstoß gegen seine Nutzungsrichtlinien prüft)	Irland und USA; Standardvertragsklauseln

Stripe (Stripe Payments Europe, Ltd., Dublin) verarbeitet nur die Zahlungsdaten des Auftraggebers als eigener Verantwortlicher und erhält keine Daten aus dem Konfigurator.

§ 8 Nennung gegenüber Betroffenen

Der Auftraggeber darf den Auftragnehmer und die Unterauftragnehmer gegenüber Betroffenen nennen. Bei Signature nennt die Datenschutzerklärung des Konfigurators den Auftragnehmer nur als technischen Dienstleister, die Unterauftragnehmer aber mit Namen. Verlangt ein Betroffener Auskunft (Art. 15 DSGVO), nennt der Auftragnehmer dem Auftraggeber auf Anfrage die konkreten Empfänger, damit dieser sie mitteilen kann (EuGH, Urteil vom 12. Januar 2023, C-154/21).

§ 9 Unterstützung des Auftraggebers

Der Auftragnehmer unterstützt den Auftraggeber bei Anfragen Betroffener (Auskunft, Berichtigung, Löschung, Einschränkung, Datenübertragbarkeit) und bei seinen Pflichten nach Art. 32 bis 36 DSGVO. Einzelne Anfragen löscht oder exportiert er auf Weisung; mit Signature kann der Auftraggeber Anfragen selbst löschen und exportieren. Wendet sich ein Betroffener direkt an den Auftragnehmer, leitet er die Anfrage an den Auftraggeber weiter. Unterstützung, die über die Funktionen des Pakets hinausgeht, kann der Auftragnehmer angemessen berechnen, außer sie ist durch einen Verstoß des Auftragnehmers nötig geworden.

§ 10 Verletzungen des Schutzes

Eine Verletzung des Schutzes personenbezogener Daten meldet der Auftragnehmer dem Auftraggeber unverzüglich nach Kenntnis, möglichst innerhalb von 48 Stunden, mit den Angaben nach Art. 33 Abs. 3 DSGVO, soweit sie vorliegen.

§ 11 Speicher- und Löschfristen

Der Auftragnehmer löscht die Daten nach diesen Fristen, ohne gesonderte Weisung; auf Weisung auch früher:

Daten	EEZI Essential	EEZI Essential Plus	EEZI Signature
Gesendete Anfragen (Aufmaß, Kontakt, Aufmaßblatt)	30 Tage nach bestätigter Zustellung der E-Mail	30 Tage nach bestätigter Zustellung der E-Mail	30 Tage nach bestätigter Zustellung der E-Mail
Originalfotos der Anfragen	mit der Anfrage	mit der Anfrage	mit der Anfrage
Link auf die Originalfotos in der E-Mail	14 Tage gültig	14 Tage gültig	kein Link
Anfrage, deren E-Mail nie zugestellt wurde	60 Tage nach dem Eingang	60 Tage nach dem Eingang	60 Tage nach dem Eingang
Begonnene Planung ohne Fenster	24 Stunden	24 Stunden	24 Stunden
Begonnene Planung mit Fenster, nicht gesendet	30 Tage nach der letzten Änderung	30 Tage nach der letzten Änderung	30 Tage nach der letzten Änderung
Testanfragen (Vorschau, Demo)	1 Tag	1 Tag	1 Tag
Alle Daten der Instanz nach Vertragsende	30 Tage nach dem Ende	30 Tage nach dem Ende	30 Tage nach dem Ende
Zählung der Anfragen je Anschluss gegen Missbrauch (Prüfwert der IP-Adresse)	2 Tage	2 Tage	2 Tage
Fehlversuche bei der Anmeldung zum Dashboard (Prüfwert der E-Mail-Adresse)	entfällt	entfällt	2 Tage
Sicherungskopien der Datenbank	7 Tage (rollierend)	7 Tage (rollierend)	7 Tage (rollierend)

Nach dem Ende des Vertrags löscht der Auftragnehmer vollständig: alle Anfragen und begonnenen Planungen, ihre Fotos, die abgelegten Aufmaßblätter, Logo und Bilder des Konfigurators, die Dateien der Bestellung, die Anmeldungen der Dashboard-Zugänge, Zwischenspeicher, die Zuordnung der Domain zum Konfigurator (die Domain selbst nach § 6 der Paketbedingungen) und den Konfigurator selbst. Auf Wunsch übergibt er vorher einen Export der noch gespeicherten Daten. In den Sicherungen sind gelöschte Daten nach spätestens sieben Tagen überschrieben. Auf Wunsch bestätigt der Auftragnehmer die Löschung in Textform.

§ 12 Nachweise und Kontrollen

Der Auftragnehmer stellt dem Auftraggeber die Informationen zur Verfügung, die zum Nachweis der Pflichten aus Art. 28 DSGVO nötig sind, vorrangig durch Unterlagen (diese Anlage, Beschreibung der Maßnahmen, Nachweise und Prüfberichte der Unterauftragnehmer). Überprüfungen vor Ort ermöglicht er höchstens einmal im Kalenderjahr, außer bei einem konkreten Anlass, nach mindestens vier Wochen Ankündigung, während der üblichen Geschäftszeiten und ohne Störung des Betriebs, durch den Auftraggeber oder einen zur Verschwiegenheit verpflichteten Prüfer, der nicht im Wettbewerb mit dem Auftragnehmer steht. Den Aufwand einer Prüfung ohne wesentlichen Befund kann der Auftragnehmer angemessen berechnen. Rechenzentren der Unterauftragnehmer werden über deren Prüfberichte geprüft.

§ 13 Schlussbestimmungen

Gegenüber Betroffenen gilt Art. 82 DSGVO. Im Verhältnis zwischen Auftraggeber und Auftragnehmer gelten die Begrenzungen aus § 12 der Paketbedingungen auch für Ansprüche aus diesem Vertrag, soweit das Gesetz nicht zwingend etwas anderes vorsieht; jede Seite trägt den Schaden, der auf ihren eigenen Pflichtverstoß zurückgeht (Art. 82 Abs. 5 DSGVO), und beruht ein Anspruch auf einer Einzelweisung des Auftraggebers, die über die Paketbedingungen hinausgeht, stellt dieser den Auftragnehmer davon frei; für die Umsetzung der vereinbarten Verarbeitung steht der Auftragnehmer selbst ein. Bei Widersprüchen geht dieser Vertrag den Paketbedingungen vor, soweit es um den Schutz personenbezogener Daten geht, nicht aber bei der Haftung.